

Why enumerate subdomains?

Expand attack surface to discover more potential points of vulnerability.

Three Methods: OSINT, Brute Force, Virtual Host

OSINT Methods:

SSL/TLS Certificate Transparency Logs

- Publicly accessible logs of every SSL/TLS certificate created
- Searchable database: <https://crt.sh>
- Contains current and historical certificate data
- Can reveal subdomains from certificate entries

Search Engines (Google Dorking)

- Use site: filter to find subdomains
- Example: `site:*.domain.com -site:www.domain.com`
- Shows only subdomain names (excludes main www domain)

Automated OSINT Tools

- Sublist3r - automates OSINT subdomain discovery methods
-

Brute Force DNS Enumeration:

Method: Trying thousands/millions of possible subdomains from a wordlist

Tool: dnsrecon

- Automates DNS enumeration with wordlists
-

Virtual Host Enumeration:

Concept:

- Web servers can host multiple websites from one server
- Server knows which site client wants from the Host header
- Subdomains may exist in private DNS or /etc/hosts files, not public DNS

Method:

- Modify Host header in requests
- Monitor responses to discover new sites
- Automate with wordlists

ffuf for Vhost Enumeration:

Basic command:

```
ffuf -w /usr/share/wordlists/SecLists/Discovery/DNS/namelist.txt -H  
"Host: FUZZ.domain.com" -u http://MACHINE_IP
```

Filter by response size:

```
ffuf -w /usr/share/wordlists/SecLists/Discovery/DNS/namelist.txt -H  
"Host: FUZZ.domain.com" -u http://MACHINE_IP -fs {size}
```

- FUZZ keyword is where wordlist entries are inserted
- -fs switch filters out responses of specified size (removes false positives)
- Look for responses with unique/different sizes than default